

Informe Pericial Forense — Incidente de Seguridad en ganga.site

Grupo 3

1. Juramento y Declaración de Abstención y Tacha

Los abajo firmantes, integrantes del Grupo 3, declaran que el presente informe ha sido elaborado con objetividad, rigor técnico e imparcialidad, sin relación de dependencia con ninguna de las partes implicadas. El análisis se ha realizado exclusivamente sobre las evidencias proporcionadas, sin extralimitarse en las conclusiones más allá de lo que los datos permiten sostener.

2. Palabras Clave

Término	Definición
Plugin	Fragmento añadido de un programa que permite otras funcionalidades
Wordpress	Herramienta para la creación de páginas web
Reflex Gallery	Plugin de Wordpress
CVE	Identificador estandarizado de vulnerabilidades conocidas (Common Vulnerabilities and Exposures)
PHP	Lenguaje de programación usado para servidores web. Wordpress está programado en este lenguaje
Post-explotación	Acciones que quien penetra un sistema lleva acabo después de la penetración para alcanzar su objetivo inicial
Memoria RAM	Memoria en la que se almacenan procesos mientras el equipo está encendido. Es volátil; se pierde casi completamente al apagarse.
Volcado de memoria (RAM dump)	Captura del contenido de la memoria volátil de un sistema en un instante determinado
Hash	Función matemática que genera un valor de longitud fija a partir de datos de entrada, usada para verificar integridad
Webshell	Archivo ejecutable subido al servidor que permite al atacante ejecutar comandos remotos
WPScan	Herramienta de reconocimiento específica para instalaciones WordPress
Anonymous mapping	Región de memoria con permisos de ejecución que no tiene ningún archivo en disco que la respalde
LiME	Módulo de los sistemas operativos Linux que permite extraer el contenido de la RAM a un archivo

3. Índice de Figuras

N.º	Figura
Figura 1	Cálculo de integridad del artefacto de disco (Disc.E01)
Figura 2	Cálculo de integridad del artefacto de memoria RAM

N.º	Figura
Figura 3	Banner del kernel — <code>Linux version 4.4.0-1061-aws</code>
Figura 4	Árbol de procesos Apache (<code>linux.pstree</code>)
Figura 5	Anonymous mappings <code>rwX</code> en <code>linux.malfind</code>
Figura 6	Endpoint vulnerable en <code>access.log</code>
Figura 7	Cuatro archivos PHP maliciosos
Figura 8	Quinto archivo PHP malicioso
Figura 9	Errores en <code>error.log</code>
Figura 10	Archivos del directorio home de <code>ubuntu</code>
Figura 11	Archivo <code>xmlrpc.php</code> activo
Figura 12	Conexiones ssh con ejecución de procesos con privilegios elevados. IP: 23.226.128.37
Figura 13	Ocurrencias de la ip sospechosa relacionadas con la web desplegada en el servidor afectado.
Figura 14	Ocurrencias de la dirección de la web con escaneos usando herramientas de análisis de vulnerabilidades.
Figura 15	Llamadas de la ip sospechos al plugin vulnerable.
Figura 16	Llamadas al plugin vulnerable de una IP adicional.

4. Resumen Ejecutivo

El presente informe analiza un incidente de seguridad ocurrido el **23 de julio de 2018** sobre un servidor Ubuntu 16.04 alojado en AWS que ejecutaba WordPress 4.8.1 en el dominio `ganga.site`. El incidente fue posible por la presencia del plugin **Reflex Gallery 3.1.3**, afectado por la vulnerabilidad **CVE-2015-4133** (*Unrestricted File Upload* sin autenticación).

Un atacante desde la dirección IP `94.242.54.22` realizó reconocimiento manual y automatizado del servidor, identificó el plugin vulnerable y procedió a subir varias puertas traseras en PHP. Posteriormente, desde una segunda IP (`88.0.112.115`), se desplegó un agente de post-explotación que quedó activo en memoria dentro de los procesos web. Los archivos PHP maliciosos fueron eliminados del disco tras su ejecución, pero su presencia queda acreditada tanto en el registro de acceso de Apache como en artefactos residentes en la memoria RAM en el momento de su adquisición.

El análisis no encontró evidencias de escalada de privilegios ni de persistencia más allá del proceso web.

5. Introducción

5.1 Antecedentes

Se pone en conocimiento del equipo de ciberseguridad de la empresa que ha ocurrido un defacement de la web de la empresa, y se procede al análisis del servidor que contiene la web. Se reciben dos artefactos:

- **Disc.E01**: imagen forense del disco duro del servidor comprometido
- **RAM.bin**: volcado de memoria RAM tomado en caliente el 24 de julio de 2018

Ambas evidencias fueron proporcionadas por el administrador del servidor, con valores hash de referencia para verificación de integridad. El análisis se inició el **15/04/2026** a las **12:10 CEST**.

5.2 Objetivos

- 1.Verificar la integridad de las evidencias recibidas.
- 2.Determinar el vector de entrada utilizado por el atacante

- 3.Reconstruir la secuencia de eventos del incidente.
- 4.Identificar los artefactos maliciosos desplegados en el sistema.
- 5.Establecer el alcance del compromiso y la presencia de persistencia.

6. Fuentes de Información

6.1 Adquisición de Evidencias

Imagen de disco — Disc.E01

Campo	Valor
Archivo recibido	Disc.E01.zip
Fuente	Administrador
Fecha de descarga	15/04/2026 — 12:12 CEST
Tamaño de la imagen	983.1 MiB (1.030.873.131 bytes)

```
kali@kali: ~/Desktop
Session Actions Edit View Help
(kali@kali)-[~/Desktop]
$ md5sum Disc.E01
bac5561328b477f0508fab7c5d9ee0a6 Disc.E01
(kali@kali)-[~/Desktop]
$ sha1sum Disc.E01
5b0a9cc8ff4ebd5aa3e1e36d8713e3b24b072e79 Disc.E01
```

(Figura 1) Cálculo de integridad del artefacto de disco.

Algoritmo	Hash calculado	Hash proporcionado	¿Coincide?
MD5	bac5561328b477f0508fab7c5d9ee0a6	bac5561328b477f0508fab7c5d9ee0a6	Sí
SHA1	5b0a9cc8ff4ebd5aa3e1e36d8713e3b24b072e79	5b0a9cc8ff4ebd5aa3e1e36d8713e3b24b072e79	Sí

```
(midex882@kali)-[~/Desktop/volatility3]
$ hashrat -md5 ../forense/proyecto_05.2/RAM.bin
hash=md5:e063c257d2f41dde65ea1fdabe64e95' type='file' mode='100644' uid='1000' gid='1000' size='1073336384' mtime='1536933828' inode='4201979' path='../forense/proyecto_05.2/RAM.bin'
(midex882@kali)-[~/Desktop/volatility3]
$ hashrat -sha1 ../forense/proyecto_05.2/RAM.bin
hash=sha1:bc2ebb435e75b3406280a2967b1c2696fc3e160a' type='file' mode='100644' uid='1000' gid='1000' size='1073336384' mtime='1536933828' inode='4201979' path='../forense/proyecto_05.2/RAM.bin'
```

(Figura 2) Cálculo de integridad del artefacto de memoria RAM.

Volcado de RAM — RAM.bin

La integridad del volcado fue verificada mediante Hashrat, con hash MD5 y SHA1 coincidentes con los valores de referencia proporcionados. El volcado fue tomado mediante LiME (Linux Memory Extractor) insertado como módulo de kernel (`insmod lime-4.4.0-1061-aws.ko`) desde una sesión SSH.

7. Análisis

7.1 Herramientas Utilizadas

Herramienta	Versión	Plataforma	Función
Autopsy	4.22.1	Windows	Análisis completo de imagen de disco: módulos de ingest, línea de tiempo, artefactos del sistema, archivos eliminados
FTK Imager	4.7.3.81	Windows	Exploración del sistema de archivos, extracción de artefactos, verificación de hashes
Volatility 3	—	Kali Linux	Análisis de volcado de memoria RAM
dwarf2json	—	Kali Linux	Conversión del debug del kernel a perfil de símbolos para Volatility
Hashrat	—	Kali Linux	Verificación de integridad de las evidencias
strings + grep	—	Kali Linux	Extracción de cadenas de texto significativas del volcado de RAM

7.2 Procesos

7.2.1 Análisis del volcado de memoria RAM

Obtención del perfil de memoria

El primer paso fue identificar la versión del kernel mediante el plugin **banners.Banners** de Volatility 3, que localizó el banner **Linux version 4.4.0-1061-aws**. Con este dato se descargó el paquete debug correspondiente desde los servidores de símbolos de Ubuntu y se generó el perfil JSON necesario para Volatility mediante **dwarf2json**.

```
(midex882@kali)-[~/Desktop/volatility3/volatility3]
$ ./dwarf2json/dwarf2json linux \
  3f- ./kernel-debug/usr/lib/debug/boot/vmlinux-4.4.0-1061-aws \
  > Ubuntu_16.04-4.4.0-1061-aws.json
```

(Figura 3) Banner del kernel — Linux version 4.4.0-1061-aws.

Análisis de procesos y código inyectado

El plugin **linux.pstree** mostró 10 procesos Apache activos (PID padre 27428 más 9 workers) con estructura padre-hijo normal y sin anidación anómala.

```

* 0x88000348ee00    27428    27428    1    apache2
** 0x880036fd8dc0    5573    5573    27428    apache2
** 0x880036f91b80    5763    5763    27428    apache2
** 0x88003c975280    6196    6196    27428    apache2
** 0x88000348a940    6262    6262    27428    apache2
** 0x88000348e040    6266    6266    27428    apache2
** 0x8800366f6040    6281    6281    27428    apache2
** 0x8800366f44c0    6285    6285    27428    apache2
** 0x8800366f2940    6286    6286    27428    apache2
** 0x880036f96040    6287    6287    27428    apache2
** 0x8800366f5280    9054    9054    27428    apache2

```

(Figura 4) Procesos Apache en pstree.

Sin embargo, **linux.malfind** detectó **regiones de memoria con permisos rwx sin archivo de respaldo en disco** en los workers PID 6262, 6266, 6281 y 6285, indicativo inequívoco de código inyectado en ejecución dentro del proceso Apache en el momento del volcado.

```
(midex882@kali)-[~/Desktop/volatility3]
$ python3 vol.py -f ../forense/proyecto_05.2/RAM.bin linux.malware.malfind
Volatility 3 Framework 2.28.1
Progress: 100.00 Stacking attempts finished
PID Process Start End Path Protection Hexdump Disasm File output
5573 apache2 0x7f0663ff3000 0x7f0664033000 Anonymous Mapping rwx
b8 17 00 00 00 00 00 00 00 00 00 00 00 00 00 .....
53 41 57 41 56 41 55 55 48 8b df 48 81 ec 20 01 SAWAVAUUH..H..
00 00 48 8b 43 10 48 83 e8 01 48 8d 74 24 38 48 ..H.C.H...H.t$8H
c7 c1 11 00 00 00 48 89 46 08 48 8d 76 08 48 83 .....H.F.H.v.H.
```

(Figura 5) Anonymous mappings rwx en malfind.

Análisis de conexiones de red

linux.sockstat mostró conexiones ssh con posterior ejecución de comandos con privilegios elevados.

4026531993	sshd	9118	9118	3	0x8800367e1680	AF_INET	STREAM	TCP	172.31.47.60	22	23.226.128.37	42760	ESTABLISHED	-	-
4026531993	sshd	9118	9118	4	0x88003cd51c00	AF_UNIX	DGRAM	-	-	110219	/run/systemd/journal/dev-log	8801	UNCONNECTED	-	-
4026531993	sshd	9118	9118	5	0x88003cd55c00	AF_UNIX	STREAM	-	-	110387	110388	ESTABLISHED	-	-	-
4026531993	sshd	14088	14088	3	0x880015404800	AF_UNIX	STREAM	-	-	116630	0	ESTABLISHED	-	-	-
4026531993	sudo	14088	14088	5	0x88017bf62000	AF_NETLINK	-	RAW	NETLINK_AUDIT	-	14088	group:0x00000000	0	UNCONNECTED	-
4026531993	sudo	14088	14088	8	0x880015403000	AF_UNIX	DGRAM	-	-	116633	/run/systemd/journal/dev-log	8801	UNCONNECTED	-	-

(Figura 12) Conexiones ssh con ejecución de procesos con privilegios elevados. IP: 23.226.128.37.

Se procede a buscar en memoria las ocurrencias de la IP 23.226.128.37.

```
[24/Jul/2018:05:18:49 +0000] "ganga.site" 23.228.128.37 TLVSlv1.2 ECDHE-RSA-AES128-GCM-SHA256 GET / HTTP/1.1 191819 "-" "Mozilla/5.0 (Windows NT 6.1; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/67.0.3396.99 Safari/537.36"
[24/Jul/2018:05:18:51 +0000] "ganga.site" 23.228.128.37 TLVSlv1.2 ECDHE-RSA-AES128-GCM-SHA256 GET /favicon.ico HTTP/1.1 286 "https://ganga.site/" "Mozilla/5.0 (Windows NT 6.1; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/67.0.3396.99 Safari/537.36"
```

(Figura 13) Ocurrencias de la ip sospechosa relacionadas con la web desplegada en el servidor afectado.

Se procede entonces a buscar ocurrencias en memoria de la dirección url de la web.

[23/Jul/2018:11:09:00 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-includes/js/autosave.js HTTP/1.1	16394	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:00 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-admin/js/editor.js HTTP/1.1	19992	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:00 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-admin/css/media.css HTTP/1.1	24138	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:01 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-includes/css/media-view-rtl.min.css HTTP/1.1	42708	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:01 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-admin/css/wp-admin.min.css HTTP/1.1	1208	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:01 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-admin/css/wp-admin.min.css HTTP/1.1	421	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:01 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-includes/js/tinymce/plugins/wpediitimage/plugin.js HTTP/1.1	31475	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:02 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-admin/quicktags.js HTTP/1.1	296	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:02 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-includes/js/wp-emol-loader.min.js HTTP/1.1	3580	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:02 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-includes/js/wp-emol-loader.js HTTP/1.1	5280	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:02 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-includes/css/media-view.min.css HTTP/1.1	42711	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:02 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-includes/css/widgets-rtl.css HTTP/1.1	13589	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:03 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-includes/css/editor.js HTTP/1.1	1349	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:03 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-includes/js/tinymce/plugins/wpediitimage/plugin.min.js HTTP/1.1	1518	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:03 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-includes/js/tinymce/plugins/wpediitimage/editor_plugin.js HTTP/1.1	1334	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:03 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/wp-includes/js/media-editor.min.js HTTP/1.1	10905	"https://ganga.site/"	WPScan v2.9.5-dev (http://wpscan.org/)
[23/Jul/2018:11:09:03 +0000]	ganga_site	4.24.254.22	TSV1-2	ECODHE-RSA-AES128-GCM-SHA256	GET	/			

(Figura 14) Ocurrencias de la dirección de la web con escaneos usando herramientas de análisis de vulnerabilidades.

Comprobamos que la web ha sido analizada en numerosas ocasiones con wpscan, una herramienta de escaneo de vulnerabilidades de wordpress. Vemos que estos escaneos los realiza otra dirección IP distinta, 94.242.54.22.

En los registros, se observa también que ha habido conexiones de esa misma IP con el plugin reflex gallery de wordpress, que posee una vulnerabilidad conocida, CVE-2015-4133 (Reflex Gallery Arbitrary File Upload). Esta vulnerabilidad permite la subida de archivos sin filtrar.

[23/Jul/2018:11:54:34 +0000] "ganga.site 88.0.112.115 TLSv1.2 ECDHE-RSA-AES128-GCM-SHA256 POST /wp-content/plugins/reflex-gallery/admin/scripts/fileUploader/php.php?Year=2018&Month=07 HTTP/1.1 57" "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"

(Figura 15) Llamadas de la ip sospechos al plugin vulnerable.

Se procede entonces a buscar ocurrencias del plugin en memoria, y se encuentran llamadas por parte de otra IP, la 88.0.112.115.

[23/Jul/2018:11:23:04 +0000] ganga.site 94.242.54.22 TLSv1.2 ECDHE-RSA-AES128-GCM-SHA256 POST /wp-content/plugins/reflex-gallery/admin/scripts/fileuploader/php.php?year=2018Month=07 HTTP/1.1 54 "-" Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
[23/Jul/2018:11:23:56 +0000] ganga.site 94.242.54.22 TLSv1.2 ECDHE-RSA-AES128-GCM-SHA256 POST /wp-content/plugins/reflex-gallery/admin/scripts/fileuploader/php.php?year=2018Month=07 HTTP/1.1 61 "-" Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
[23/Jul/2018:11:25:35 +0000] ganga.site 88.0.112.115 TLSv1.2 ECDHE-RSA-AES128-GCM-SHA256 POST /wp-content/plugins/reflex-gallery/admin/scripts/fileuploader/php.php?year=2018Month=07 HTTP/1.1 61 "-" Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
[23/Jul/2018:11:54:34 +0000] ganga.site 88.0.112.115 TLSv1.2 ECDHE-RSA-AES128-GCM-SHA256 POST /wp-content/plugins/reflex-gallery/admin/scripts/fileuploader/php.php?year=2018Month=07 HTTP/1.1 57 "-" Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)

(Figura 16) Llamadas al plugin vulnerable de una IP adicional.

7.2.2 Análisis de la imagen de disco

Vector de entrada — CVE-2015-4133

El examen de `/var/log/apache2/access.log` reveló el vector de ataque. A las 11:08 UTC del 23/07/2018, la IP `94.242.54.22` lanzó WPScan v2.9.5-dev contra el servidor. El scanner descargó el archivo `readme.txt` del plugin Reflex Gallery con respuesta HTTP 200, exponiendo la versión **3.1.3**, afectada por CVE-2015-4133 (*Unrestricted File Upload* — carga de archivos arbitrarios sin autenticación). A las 11:20 UTC se inició la explotación mediante POST al endpoint `wp-content/plugins/reflex-gallery/FileUploader/php.php`.

```
[23/Jul/2018:11:20:26 +0000] ganga.site 94.242.54.22 TLSv1.2 ECDHE-RSA-AES128-GCM-SHA256 POST /wp-content/plugins/reflex-gallery/admin/scripts/FileUploader//php.php?Year=2018&Month=07 HTTP/1.1 55 "-" "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
218.211.168.176 - - [23/Jul/2018:11:22:49 +0000] "GET / HTTP/1.1" 200 606 "-" "Mozilla/5.0"
```

(Figura 6) Endpoint vulnerable en access.log.

Atributo	Valor
Ruta	<code>/var/log/apache2/access.log</code>
Tamaño	108 KB
MD5	325d4e7fad4213e46faf58dcf76af017
SHA256	46BF61392DE369143890AE080E91502050F9478CD3D1DCB063C8223A6E58662E
Date Created	23/07/2018 06:25:01 UTC
Date Modified	24/07/2018 05:19:11 UTC

Webshells desplegadas

Se identificaron cinco archivos PHP maliciosos subidos al directorio `/wp-content/uploads/2018/07/`. Los nombres aleatorios de entre 8 y 16 caracteres son consistentes con la función `rand_text_alpha` del módulo Metasploit `exploit/unix/webapp/wp_reflexgallery_file_upload`. Todos devolvieron HTTP 200 al ser ejecutados, confirmando su correcta ejecución por el servidor.

```
[23/Jul/2018:11:20:28 +0000] ganga.site 94.242.54.22 TLSv1.2 ECDHE-RSA-AES128-GCM-SHA256 GET /wp-content/uploads/2018/07//PSMOfbPom.php HTTP/1.1 2 "-" "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
[23/Jul/2018:11:23:57 +0000] ganga.site 94.242.54.22 TLSv1.2 ECDHE-RSA-AES128-GCM-SHA256 GET /wp-content/uploads/2018/07//XLPYh1EtQOyiMKb.php HTTP/1.1 2 "-" "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
[23/Jul/2018:11:25:35 +0000] ganga.site 88.0.112.115 TLSv1.2 ECDHE-RSA-AES128-GCM-SHA256 POST /wp-content/plugins/reflex-gallery/admin/scripts/FileUploader/php.php?Year=2018&Month=07 HTTP/1.1 61 "-" "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
[23/Jul/2018:11:23:05 +0000] ganga.site 94.242.54.22 TLSv1.2 ECDHE-RSA-AES128-GCM-SHA256 GET /wp-content/uploads/2018/07//yDdoSpsx.php HTTP/1.1 2 "-" "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
88.132.175.225 - - [23/Jul/2018:11:41:11 +0000] "GET / HTTP/1.0" 200 982 "-" "Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; WOW64; Trident/5.0)"
[23/Jul/2018:11:25:35 +0000] ganga.site 88.0.112.115 TLSv1.2 ECDHE-RSA-AES128-GCM-SHA256 GET /wp-content/uploads/2018/07//vmGABaiewrSSuMs.php HTTP/1.1 2 "-" "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
```

(Figura 7) Cuatro archivos PHP maliciosos.

```
[23/Jul/2018:11:54:34 +0000] ganga.site 88.0.112.115 TLSv1.2 ECDHE-RSA-AES128-GCM-SHA256 GET /wp-content/uploads/2018/07//PLoeJFOEVoc.php HTTP/1.1 2 "-" "Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
```

(Figura 8) Quinto archivo PHP malicioso.

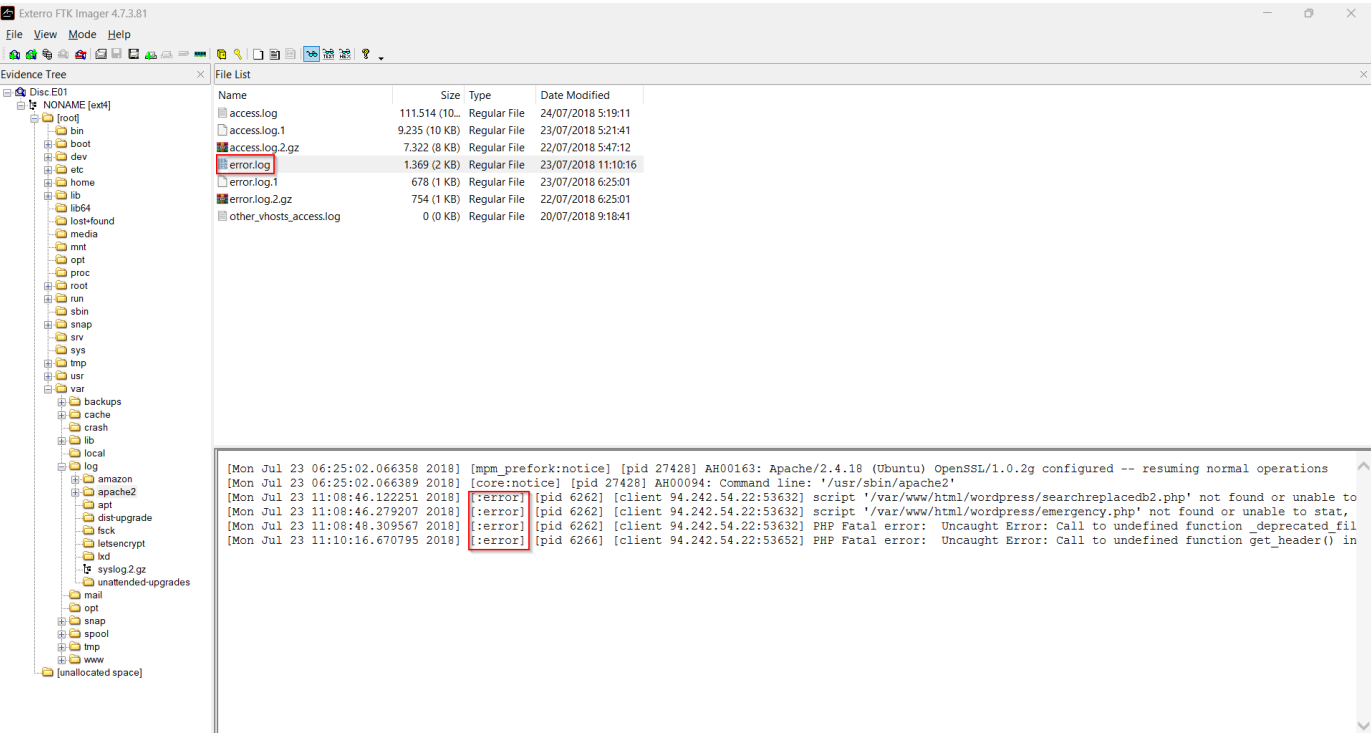
Archivo	IP origen	Hora UTC
<code>PSMOfbPom.php</code>	<code>94.242.54.22</code>	11:20:26
<code>yDdoSpsx.php</code>	<code>94.242.54.22</code>	11:20:28
<code>XLPYh1EtQOyiMKb.php</code>	<code>94.242.54.22</code>	11:23:57
<code>vmGABaiewrSSuMs.php</code>	<code>88.0.112.115</code>	11:25:35
<code>PLoeJFOEVoc.php</code>	<code>88.0.112.115</code>	11:54:34

Los archivos PHP no fueron recuperados en el sistema de archivos, lo que indica que el atacante los eliminó del disco tras su ejecución. Los timestamps del directorio de uploads (**Date Modified 11:54:36**, **Date Accessed 11:54:56**) corroboran la escritura y ejecución durante la segunda sesión de ataque.

Error log de Apache

`/var/log/apache2/error.log` aportó evidencia complementaria. La ausencia de `searchreplacedb2.php` y `emergency.php` en el servidor a las 11:08:46 confirma que no existían compromisos previos al ataque documentado. Los errores PHP fatales en

rss-functions.php (11:08:48) y en index.php del tema twentyseventeen (11:10:16) son consecuencia directa del fingerprinting agresivo de WPScan y revelan la ruta absoluta del servidor: /var/www/html/wordpress/.



(Figura 9) Errores en error.log.

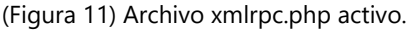
Atributo	Valor
Ruta	/var/log/apache2/error.log
Tamaño	2 KB
MD5	496044572974077b25d87ecc950ec4bc
SHA256	A8F34244C110114462935045C11C9208F846B54ABE47EA69909EBBD46518EAEC
Date Created	23/07/2018 06:25:01 UTC
Date Modified	23/07/2018 11:10:16 UTC

Artefactos del administrador — /home/ubuntu/

Los artefactos presentes en el directorio home del usuario ubuntu (.bash_history, .mysql_history, .viminfo, authorized_keys) tienen todos su última modificación el 20/07/2018 y ninguno registra acceso el día del ataque. Esto confirma que el atacante no obtuvo acceso interactivo al sistema ni modificó el entorno del usuario administrador. El .bash_history documenta la instalación del stack y el despliegue de WordPress 4.8.1; el .mysql_history confirma la creación de la base de datos ganga con conexión al endpoint RDS de Amazon ganga.ctmbcxcdb3us.eu-central-1.rds.amazonaws.com.



El archivo `/var/www/html/wordpress/xmlrpc.php` estaba presente y activo, con `Date Accessed` en `23/07/2018 11:08:46`, coincidiendo exactamente con las peticiones de WPScan. El archivo corresponde al original de WordPress sin modificaciones, pero su exposición supone un vector de ataque adicional para fuerza bruta amplificada mediante `system.multicall` y abuso de pingbacks.



8 / 10

Limitación	Descripción
IP del servidor de mando y control (LHOST) no recuperada	Los sockets TCP de Apache aparecen en estado CLOSE en el volcado. La dirección IP del C2 de Metasploit podría recuperarse mediante análisis binario de las regiones rwx volcadas por malfind , lo que queda fuera del alcance de este análisis
Archivos PHP maliciosos eliminados del disco	Los cinco archivos PHP no están presentes en el sistema de archivos de la imagen de disco. Su existencia queda acreditada por los logs y por los artefactos en RAM, pero no es posible realizar análisis estático de su código desde el disco
Relación entre 94.242.54.22 y 88.0.112.115 no determinada	No es posible confirmar con los datos disponibles si ambas IPs corresponden al mismo actor (uso de VPN o pivot) o a dos actores distintos coordinados
Ausencia de registros de red adicionales	No se dispone de capturas de tráfico (PCAP) ni registros de cortafuegos que permitan correlacionar las conexiones a nivel de paquete

9. Conclusiones

El 23 de julio de 2018, un atacante identificó el plugin Reflex Gallery 3.1.3 instalado en el WordPress de **ganga.site** mediante reconocimiento manual y automatizado con WPScan, y explotó la vulnerabilidad CVE-2015-4133 para subir cinco archivos PHP sin necesidad de autenticación. Una de las cargas maliciosas (**vmGAbaiewrSSuMs.php**) contenía un agente Meterpreter de Metasploit que se ejecutó dentro del proceso Apache y quedó residente en memoria hasta el momento del volcado, aunque su canal de comunicación con el servidor de mando y control ya había cerrado. Los archivos PHP fueron eliminados del disco tras su ejecución, pero su existencia y ejecución quedan acreditadas por los registros de Apache y por los artefactos recuperados de la memoria RAM.

No se encontró evidencia de escalada de privilegios al usuario **ubuntu**, de modificación del core de WordPress, de persistencia más allá del proceso Apache ni de actividad maliciosa previa al 23 de julio de 2018.

10. Anexos

Anexo 1. Sobre el Perito

Campo	Valor
Grupo	Grupo 3
Asignatura	Análisis Forense Informático
Fecha del informe	20/04/2026

Anexo 2. Sumas de Verificación

Evidencia	Algoritmo	Hash
Disc.E01	MD5	bac5561328b477f0508fab7c5d9ee0a6
Disc.E01	SHA1	5b0a9cc8ff4ebd5aa3e1e36d8713e3b24b072e79
RAM.bin	MD5	(valor del hashrat)
RAM.bin	SHA1	(valor del hashrat)
access.log	MD5	325d4e7fad4213e46faf58dcf76af017
access.log	SHA256	46BF61392DE369143890AE080E91502050F9478CD3D1DCB063C8223A6E58662E
error.log	MD5	496044572974077b25d87ecc950ec4bc
error.log	SHA256	A8F34244C110114462935045C11C9208F846B54ABE47EA69909EBBD46518EAEC

Evidencia	Algoritmo	Hash
xmlrpc.php	MD5	6c53e2ff076280c5cfc410a3c632c785
xmlrpc.php	SHA256	639CD36E1C7262A5DF907DFBDFCC5F3BC64E152A9389AAF5DE606F17A1434314

Perito forense y
responsable de Grupo 3
Forensics SA

Jose Escalón
Escalón